FDE INTERVIEW PREP #07

FDE INTERVIEW PREP · ISSUE 07 OF 08

Security and governance questions.

OAuth2, OIDC, JWT, RBAC, secrets, AI threats and PII.

07

AR

Akhilesh Ranjan Singh

Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

Questions and short answers

01 **OAuth2 vs OIDC?**

OAuth2 grants access. OIDC adds identity on top.

02 **Validating a JWT?**

Signature, issuer, audience, expiry, every request.

03 **RBAC or ABAC?**

RBAC for roles. ABAC when access depends on the record.

04 **Secrets?**

Vault plus workload identity. Nothing static.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

AI threat model, short form

THREAT	CONTROL
Prompt injection	Least-privilege tools, approvals
Data leakage	Permission filter at retrieval
PII exposure	Redaction, minimisation, retention
Over-permissive agent	Scoped identity per tool

AR
Akhilesh Ranjan Singh
github.com/iarsingh

Privacy follow-ups

01 PII sent to an LLM?

Minimise, mask, or use a model in their boundary.

02 Data residency?

Region-pinned services, documented data flows.

03 Audit?

Who asked what, which data, which tool, when.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

How to answer

DO

- ✓ Draw trust boundaries
- ✓ Name the control per threat
- ✓ Bring security in early
- ✓ Offer evidence, not promises

AVOID

- ✗ “The model is safe”
- ✗ Prompt-only defences
- ✗ Treat security as a blocker
- ✗ Store data you do not need

AR
Akhilesh Ranjan Singh
github.com/iarsingh

Practise these

- [x] Explain an OIDC login flow
- [x] Threat model a RAG assistant
- [x] Defend against prompt injection
- [x] Design a PII redaction step
- [x] Write a data flow diagram

AR
Akhilesh Ranjan Singh
github.com/iarsingh

KEY TAKEAWAY

Make the security review easy to say yes to.

→ Know OAuth2, OIDC and JWT cold

→ One control per named threat

→ Minimise the data you touch

YOUR TURN

What question from a security team caught you off guard?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #08 The customer questions in an FDE loop

Save · Repost

AR
Akhilesh Ranjan Singh
github.com/iarsingh